

Lecture 2:

Risk Management and Threat Modeling

Eleftheria Makri | Security

11/02/2025



Universiteit
Leiden

Bij ons leer je de wereld kennen

Risk Management and Threat Modeling

- Definition of Risk and Related Terminology
- Risk Management
 - Qualitative Risk Assessment
 - Quantitative Risk Assessment
 - Strategies Against Risk
 - Cost Benefit Analysis
- Security Design Principles, Best Practices, and Standards
- Threat Modeling

Risk Management

Asset



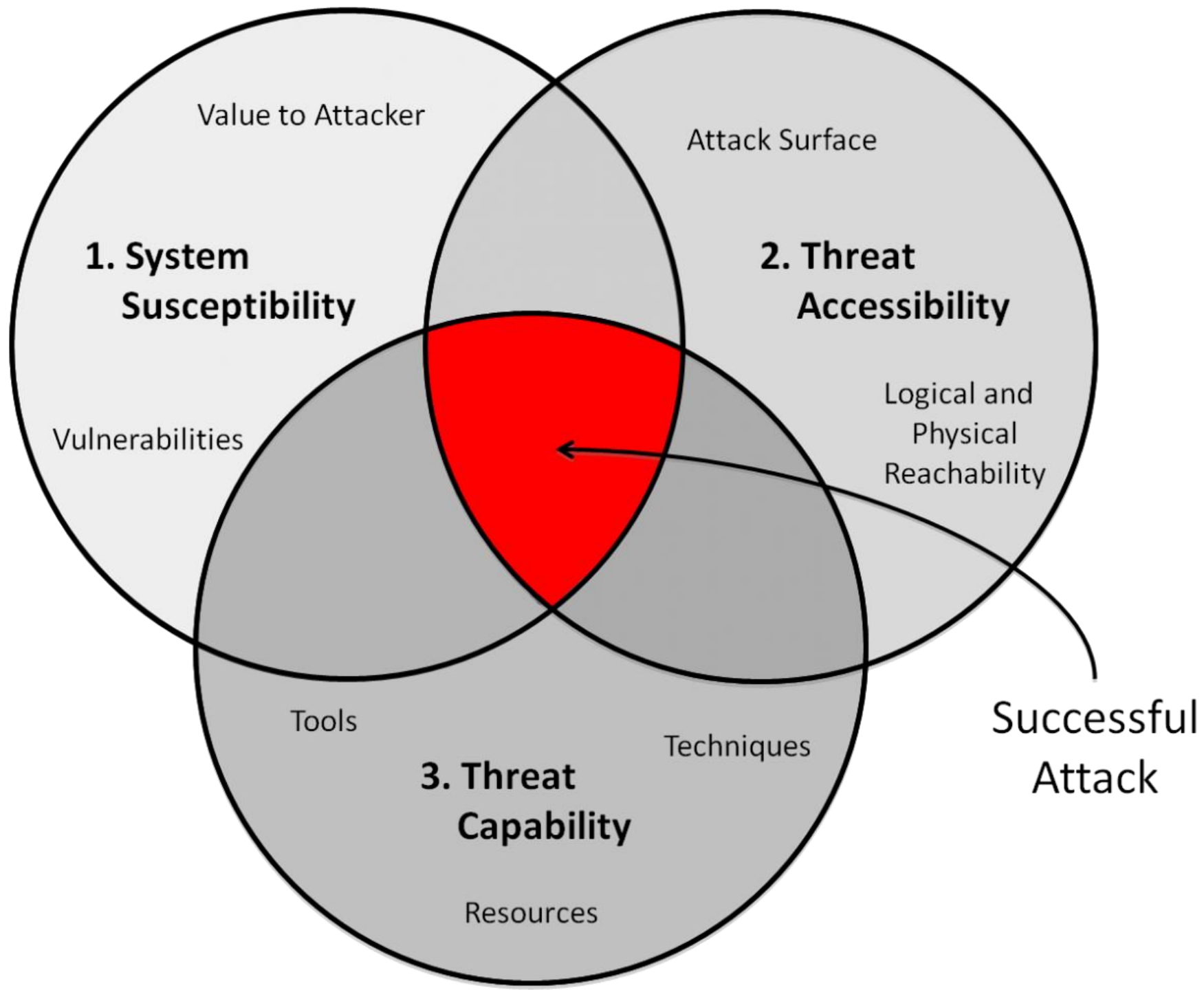
Vulnerability

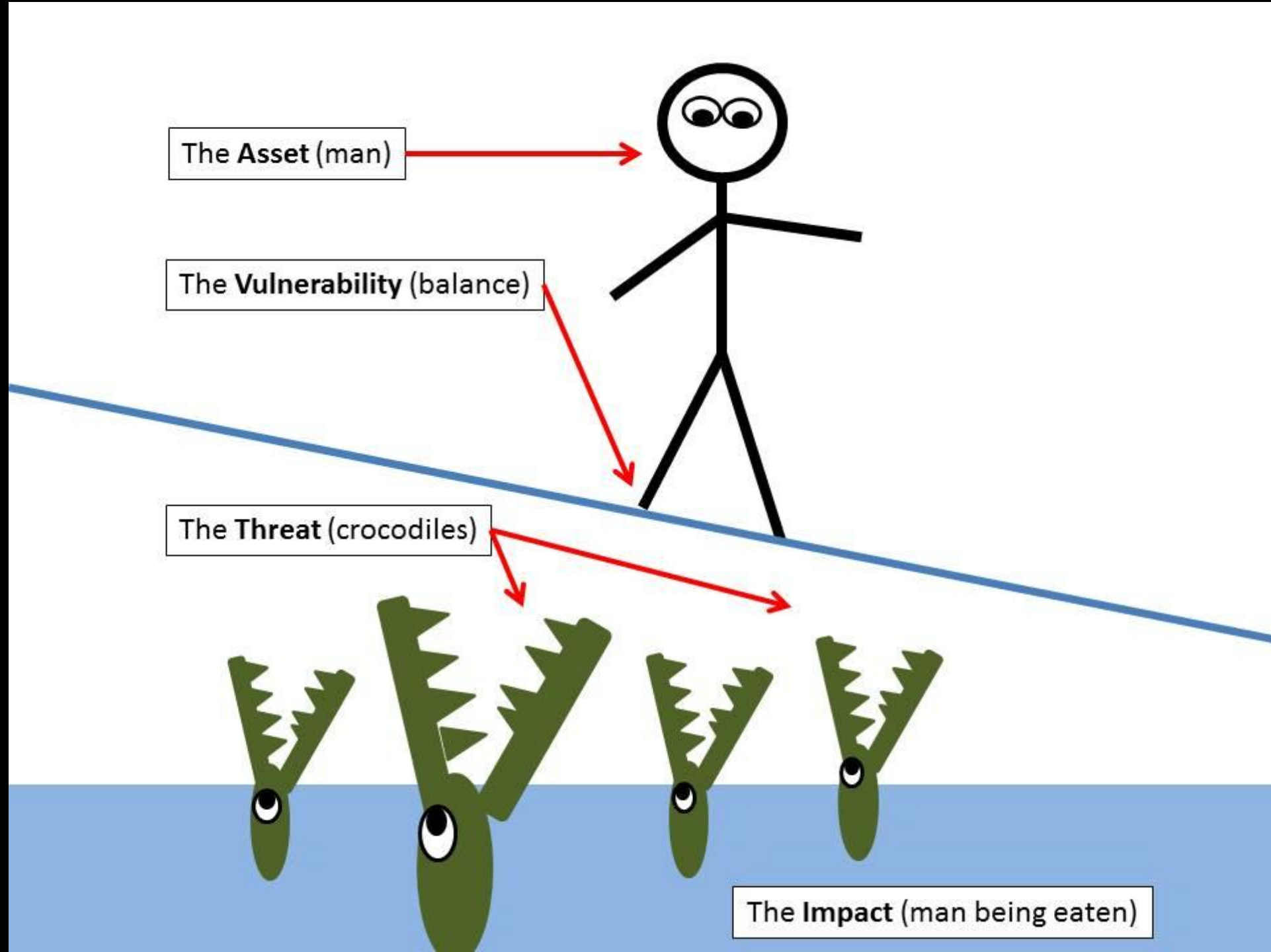


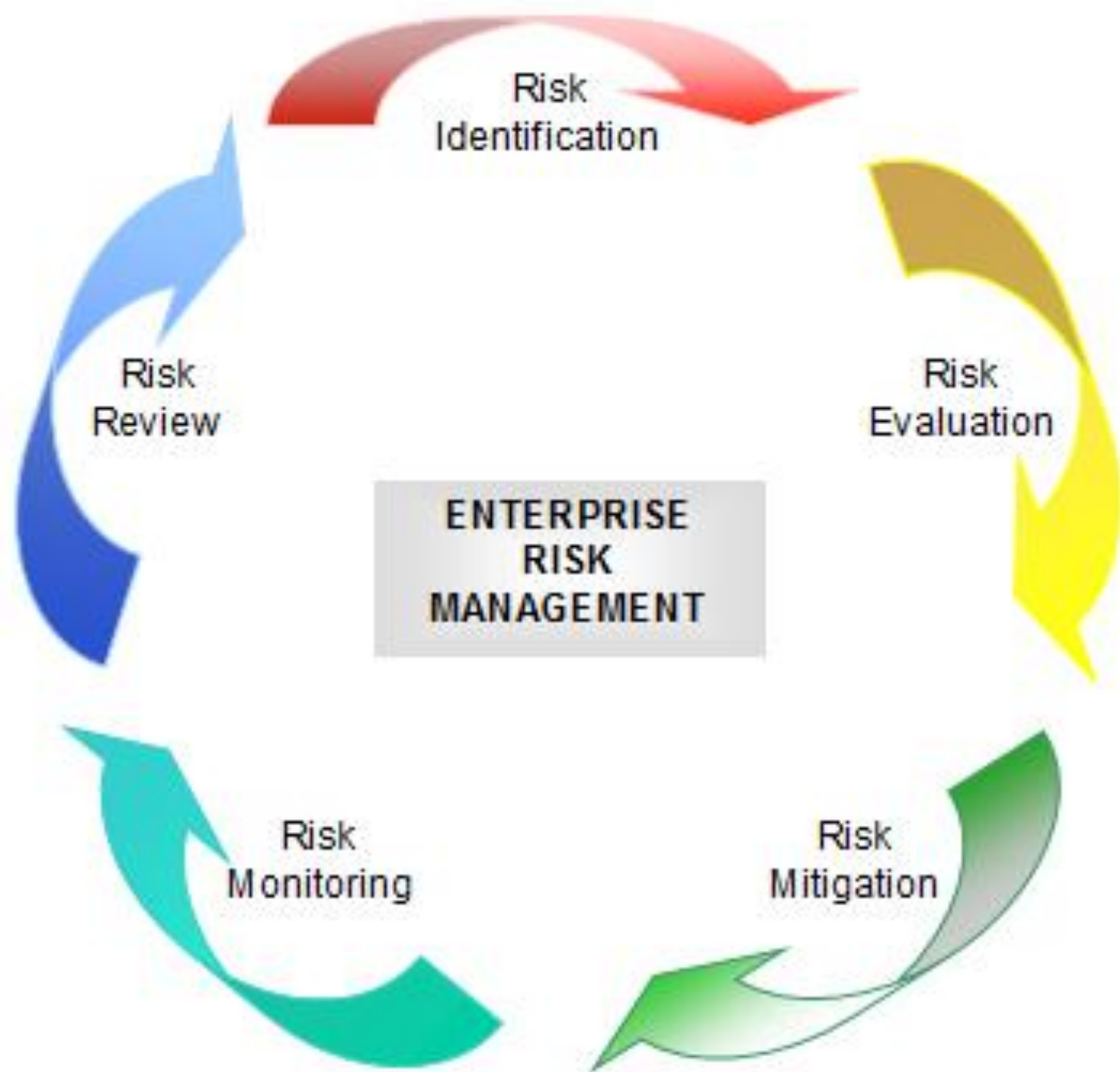


threat

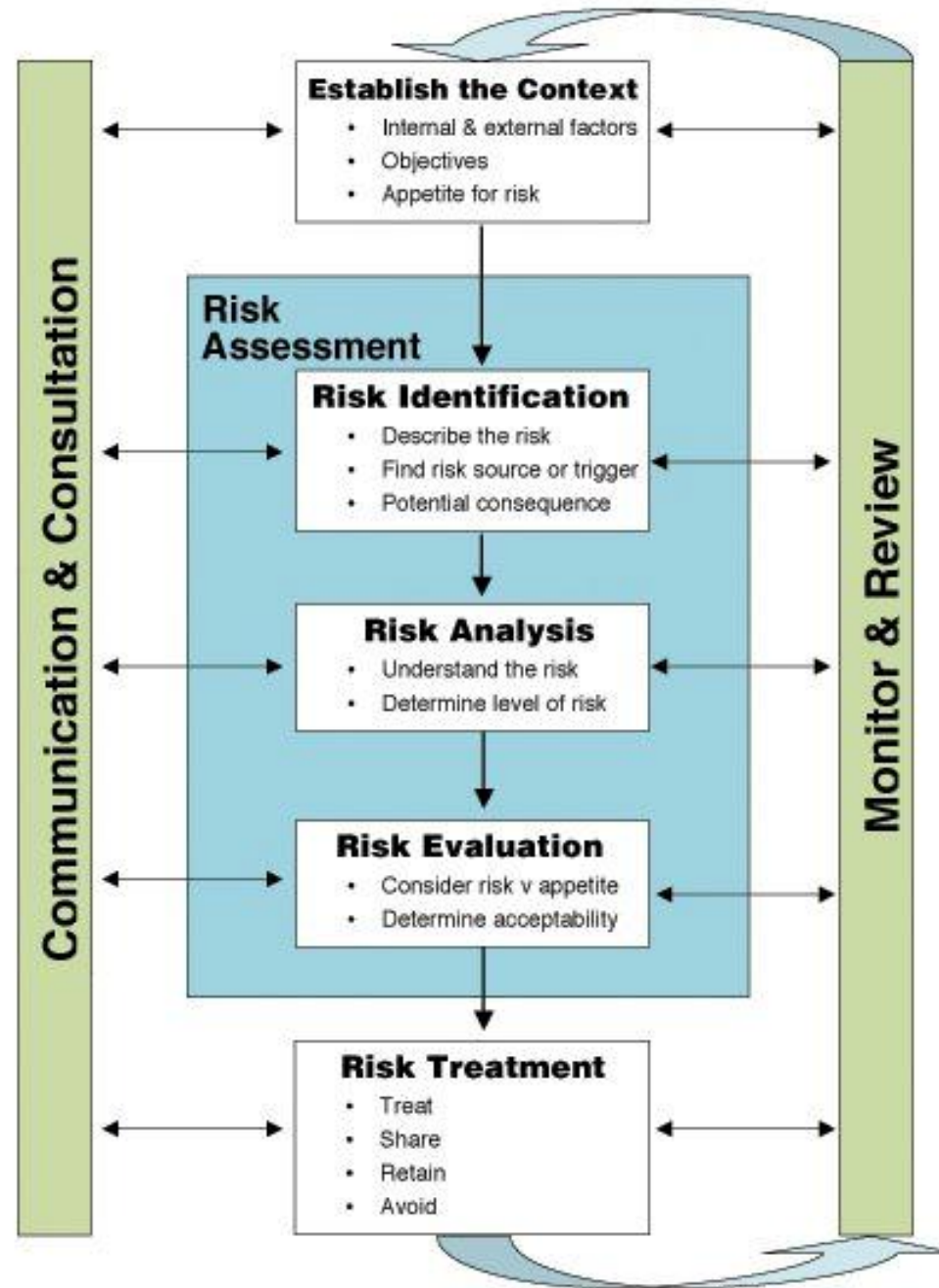








ISO 31000 Risk Management Process



Qualitative Risk Assessment

Likelihood	Impact				
	Insignificant	Minor	Moderate	Major	Severe
Almost certain	Moderate	High	High	Extreme	Extreme
Likely	Moderate	Moderate	High	High	Extreme
Possible	Low	Moderate	Moderate	High	Extreme
Unlikely	Low	Moderate	Moderate	Moderate	High
Rare	Low	Low	Moderate	Moderate	High

Quantitative Risk Assessment

Risk Rating = Likelihood x Severity

S e v e r i t y	Catastrophic	5	5	10	15	20	25
	Significant	4	4	8	12	16	20
	Moderate	3	3	6	9	12	15
	Low	2	2	4	6	8	10
	Negligible	1	1	2	3	4	5
			1	2	3	4	5
			Improbable	Remote	Occasional	Probable	Frequent
			Likelihood				

Catastrophic		STOP
Unacceptable		URGENT ACTION
Undesirable		ACTION
Acceptable		MONITOR
Desirable		NO ACTION

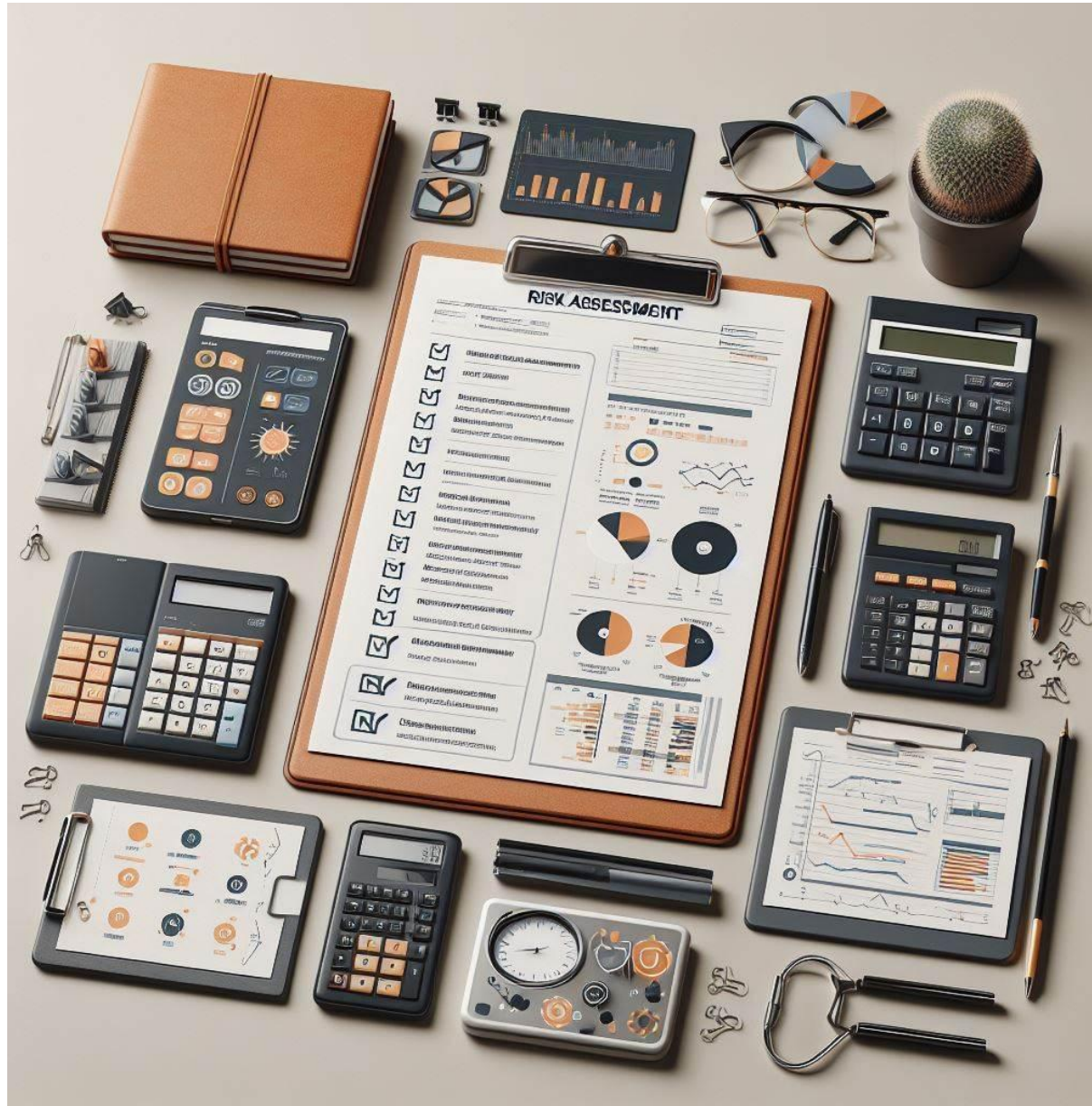
Identify Vulnerabilities



Identify Threats



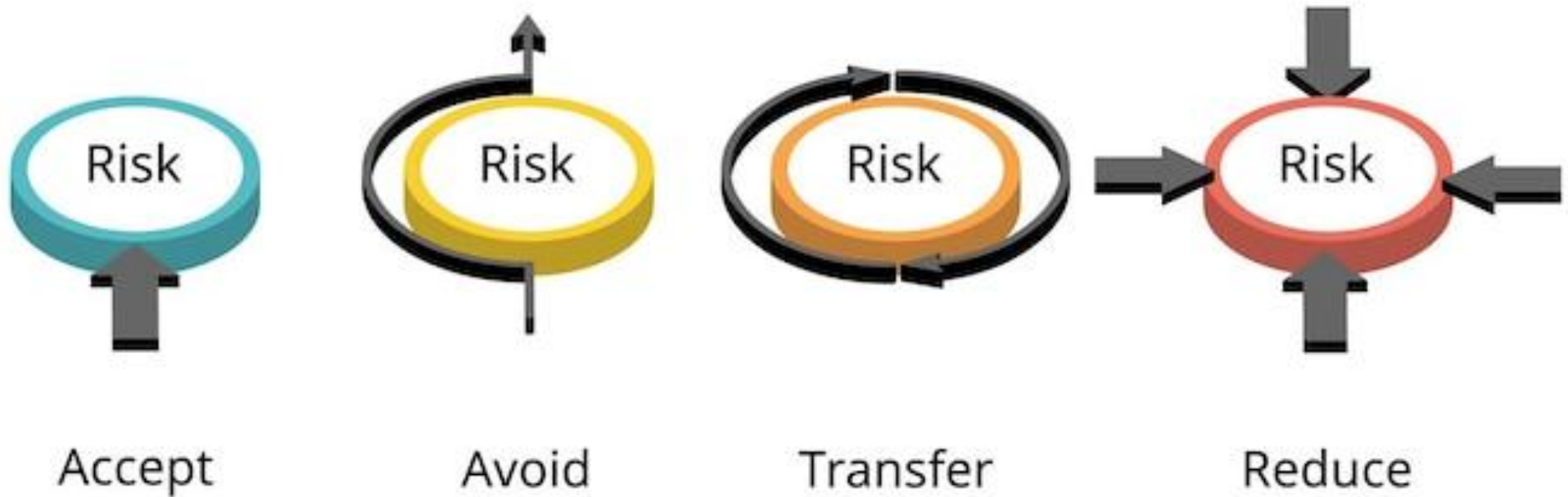
Select Tools and Techniques for Risk Assessment



Strategies Against Risk



Four Strategies Against Risk



Considerations for Countermeasures

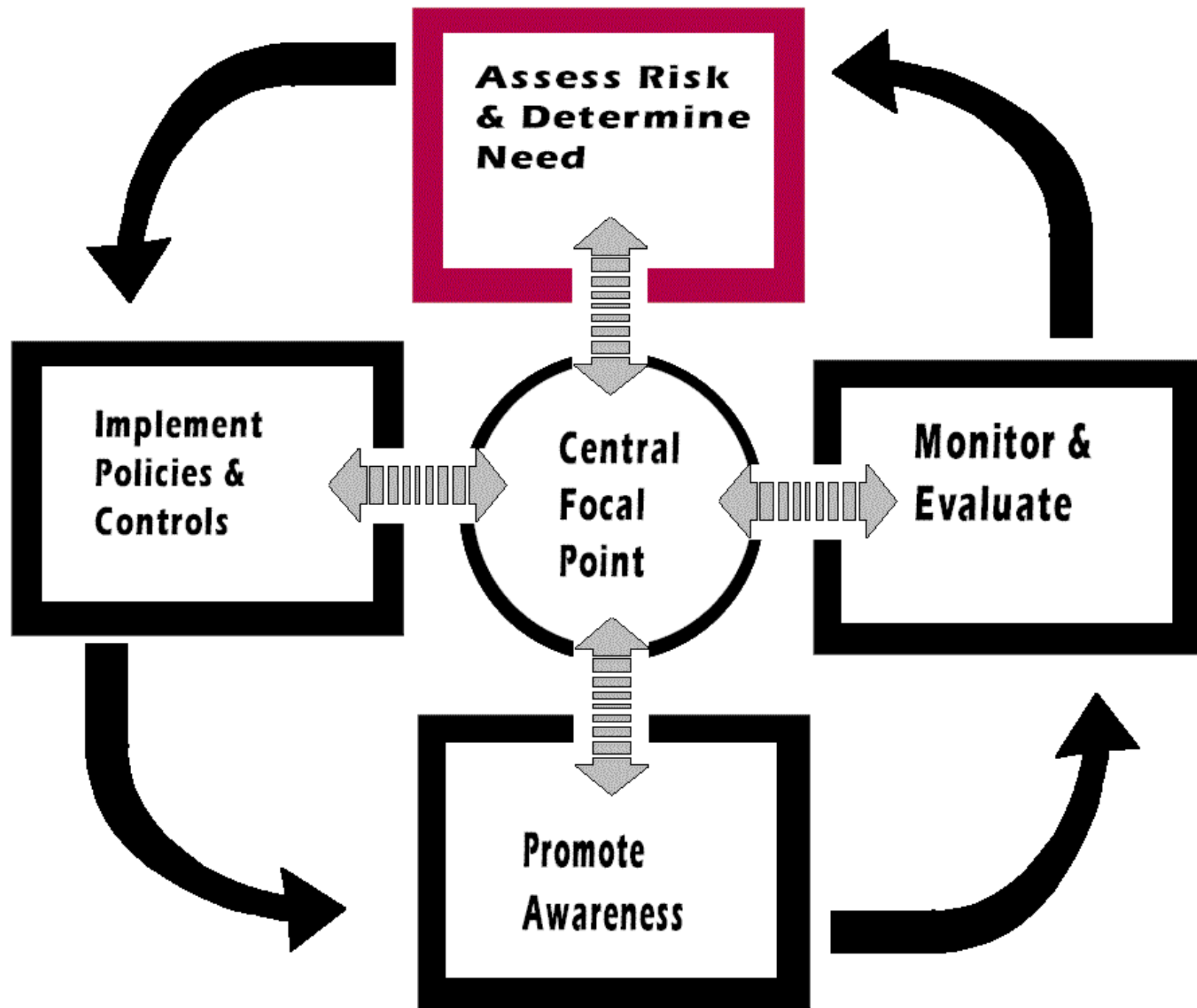


Asset Valuation and Cost Benefit Analysis



Example: Risk of data disclosure

Before installing controls	
Cost to recover data	US\$1,000,000
Likelihood (per year)	10%
Risk exposure: expected cost of incidents	US\$ 100,000
After installing controls	
Effectiveness of access control (risk reduction factor)	60%
Expected cost of incidents	US\$ 40,000
Costs of acquiring AC software	US\$ 25,000
Expected total cost	US\$ 65,000
Savings	
Savings per year	US\$ 35,000
Risk reduction	
$100.000 * 60\%$	US\$ 60,000
Risk leverage	
$(100,000-40,000):25,000$	2.4
Return on security investment factor (ROSI)	
$(60,000-25,000):25,000$	1.4



Let's Practice!

Risk Assessment Github

Consider the GitHub platform (github.com) that is used by millions of developers to store their code.

- a. Identify three (3) important assets for GitHub.
- b. Identify three (3) threat scenarios that can have impact on the service owner (GitHub).
- c. Discuss how the identified assets can be impacted by these three (3) threat scenarios.
- d. Quantify these three (3) risks by estimating their likelihood and impact.
- e. Discuss one countermeasure per risk identified in (d), i.e., three (3) in total. Countermeasures can already be implemented or not yet implemented.

Risk Assessment Github – Grading (a)

Consider the GitHub platform (github.com) that is used by millions of developers to store their code.

a. Identify three (3) important assets for GitHub. – 2.0 points

Important aspects: assets should be relevant to the platform.

2.0p 4a Identify three (3) important assets for GitHub.

- 1) The public code content (the codes of users stored in the public repositories created for the educational purposes: topic - BFS algorithms)
- 2) The system itself - so the server and software where the website is run
- 3) The private data of users, including the private repositories.

48 words

Risk Assessment Github – Grading (b)

Consider the GitHub platform (github.com) that is used by millions of developers to store their code.

b. Identify three (3) threat scenarios that can have impact on the service owner (GitHub). – 2.0 points

Important aspects: Threat scenarios should be diverse

2.0p 4b Identify three (3) threat scenarios that can have impact on the service owner (GitHub).

- 1) An attacker deletes or modifies the educative repositories stored in the server database which were not supposed to be modified by the unauthorized parties. Is done by the means of the SQL injection where an attacker inserts malicious SQL code to the input fields of the log in page and gets an access to the database.
- 2) DDoS attack such as SYN Flooding, where an attacker sends many SYN packets to a server so that its connection table would become overloaded due to the waiting reply.
- 3) An attacker logs in to the github account of authenticated users using CSRF attack. An attacker crafts the malicious webpage and tricks a user with the stores in the website cookies to to to it and click an image. The malicious image actually make a request to the github platform and the attacker gets an access to the users' private data due to the stored cookies needed for authentication.

Risk Assessment Github – Grading (c)

Consider the GitHub platform (github.com) that is used by millions of developers to store their code.

c. Discuss how the identified assets can be impacted by these three (3) threat scenarios. . – 2.0 points

Important aspects: Impacts should be relevant to GitHub.

2.0p 4c Discuss how the identified assets can be impacted by these three (3) threat scenarios.

- 1) Violates Integrity of the system and can lead to high financial costs to recover the lost codes needed so much for education.
- 2) Violates Availability of a system, which damage the Reputation of the service provider.
- 3) Violates Confidentiality of a system, which can lead to the mental health impact os particular users.

54 words

Risk Assessment Github – Grading (d)

Consider the GitHub platform (github.com) that is used by millions of developers to store their code.

d. Quantify these three (3) risks by estimating their likelihood and impact. – 2.0 points

Important aspects: Risk quantification should include justified estimates of probability and impact; the answer should demonstrate knowledge of the main risk quantification formula: $\text{risk} = \text{impact} \times \text{likelihood}$.

2.0p 4d Quantify these three (3) risks by estimating their likelihood and impact.

- 1) The impact on the educative codes are 10000 dollars. The likelihood of occurrence is 20% so the risk is $10000 \times 0.2 = 2000$ dollars
- 2) The cost is 200000 dollars. The likelihood is 25%. The risk estimation = $\text{cost} \times \text{likelihood} = 50000$ dollars.
- 3) The impact of an attack per user is 1000 dollars. The likelihood is 30%. The risk estimation is $1000 \times 0.3 = 300$ dollars

65 words

Risk Assessment Github – Grading (e)

Consider the GitHub platform (github.com) that is used by millions of developers to store their code.

e. Discuss one countermeasure per risk identified in (d), i.e., three (3) in total. Countermeasures can already be implemented or not yet implemented. – 2.0 points

Important aspects: Countermeasures should be adequate for the considered threat scenarios.

2.0p 4e Discuss one countermeasure per risk identified in d, i.e., three (3) in total. Countermeasures can already be implemented or not yet implemented.

1) Implement the Defence in Depth:

Limit the privilege of a server

Encrypt the data in the database

Input sanitizing (blacklisting, escaping, prepared statements)

Input check (whitelisting)

2) Load balancing (distribute the traffic among multiple servers)

Ask for help from the upstream service providers

3) Include REFERER field to the HTTP header: URL of the previous website from which the request came from and check this field for cross-site attacks.

70 words

Risk Assessment Github – Common Fallacies

- 1.
1. Password bruteforcing
 2. Denial of Service Attack
 3. Persistent Cross Site Scripting Attack

14 words

4b Identify three (3) threat scenarios that can have impact on the service owner (GitHub).

1.5 / 2.0 points

Edited by Makri, Eleftheria 8 months ago

1

2 pts

Threat scenarios should be diverse

+Comment

0

0 points

None of the above

+Comment



+1.5 points

generic attacks; no attempt to relate to the use case

+ Adjustment

2. d. Quantify these three (3) risks by estimating their likelihood and impact.

The answer does NOT demonstrate knowledge of the main risk quantification formula: $\text{risk} = \text{impact} \times \text{likelihood}$. (nor can it be implied by the computations)

Principles, Best Practices and Standards

Design Principles (just 2 indicative)

Separation of Duties



Example of Conflicts – SoD to be applied

Function/ Processes \ Roles	Create Vendor	Change Vendor	Post Goods Receipt	Post Payment	Process Inventory	Goods Issue	Maintain PO
Create Vendor		X	X	X			X
Change Vendor	X		X	X			X
Post Goods Receipt	X	X		X	X	X	X
Post Payment	X	X	X			X	X
Process Inventory			X				X
Goods Issue			X	X			
Maintain PO	X	X	X	X	X		

X - Existence of Conflict

Least Privilege Principle



Best Practices and Standards

Standards



International
Organization for
Standardization

NIST
**National Institute of
Standards and Technology**
U.S. Department of Commerce



Compliance



Security and Audit Frameworks



Important Documents

- **ISO/IEC 27000 series:** a set of standard on information security management systems (ISMSs)
- **ISO 31000:** risk management standard
- **NIST 800-30:** guide for conducting risk assessments
<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
- **NIST 800-53:** security and privacy controls
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- **ISACA COBIT:** a framework for IT systems management

Methods for Risk Management

- **Tabular methods** — popular in industry
- **Graphical methods** — popular in academic circles

Tabular Risk Management: NIST 800-30

TABLE I-5: TEMPLATE – ADVERSARIAL RISK

[illegible]

Column	Heading	Content
1	Threat Event	Identify threat event. (Task 2-2; Table E-1; Table E-2; Table E-5; Table I-5.)
2	Threat Sources	Identify threat sources that could initiate the threat event. (Task 2-1; Table D-1; Table D-2; Table D-7; Table I-5.)
3	Capability	Assess threat source capability. (Task 2-1; Table D-3; Table D-7; Table I-5.)
4	Intent	Assess threat source intent. (Task 2-1; Table D-4; Table D-7; Table I-5.)
5	Targeting	Assess threat source targeting. (Task 2-1; Table D-5; Table D-7; Table I-5.)
6	Relevance	Determine relevance of threat event. (Task 2-2; Table E-1; Table E-4; Table E-5; Table I-5.) If the relevance of the threat event does not meet the organization's criteria for further consideration, do not complete the remaining columns.
7	Likelihood of Attack Initiation	Determine likelihood that one or more of the threat sources initiates the threat event, taking into consideration capability, intent, and targeting. (Task 2-4; Table G-1; Table G-2; Table I-5.)
8	Vulnerabilities and Predisposing Conditions	Identify vulnerabilities which could be exploited by threat sources initiating the threat event and the predisposing conditions which could increase the likelihood of adverse impacts. (Task 2-5; Table F-1; Table F-3; Table F-4; Table F-6; Table I-5.)
9	Severity Pervasiveness	Assess severity of vulnerabilities and pervasiveness of predisposing conditions. (Task 2-5; Table F-1; Table F-2; Table F-5; Table F-6; Table I-5.)
10	Likelihood Initiated Attack Succeeds	Determine the likelihood that the threat event, once initiated, will result in adverse impact, taking into consideration threat source capability, vulnerabilities, and predisposing conditions. (Task 2-4; Table G-1; Table G-4; Table I-5.)
11	Overall Likelihood	Determine the likelihood that the threat event will be initiated and result in adverse impact (i.e., combination of likelihood of attack initiation and likelihood that initiated attack succeeds). (Task 2-4; Table G-1; Table G-5; Table I-5.)
12	Level of Impact	Determine the adverse impact (i.e., potential harm to organizational operations, organizational assets, individuals, other organizations, or the Nation) from the threat event. (Task 2-5; Table H-1; Table H-2; Table H-3; Table H-4; Table I-5.)
13	Risk	Determine the level of risk as a combination of likelihood and impact. (Task 2-6; Table I-1; Table I-2; Table I-3; Table I-5.)

Threat Modeling

STRIDE

Threat	Concern	Countermeasures
Spoofing	Can you trust the identity of this entity (user, process, etc.) ?	Authentication, session management, digital certificates
Tampering	Can you trust the integrity of the data? Can someone change it?	Digital signatures, access control, auditing
Repudiation	Can you prove who did something and when they did it?	Auditing and logging, digital certificates and digital signatures
Information disclosure	Is there a risk of data theft or a data leak?	Access control, encryption
Denial of service	Can someone stop authorised users from getting access to the system?	Rate limiting, boundary protection, redundancy, elastic resources
Elevation of privilege	Can an unprivileged user gain privilege system access?	Authorization and access control, least privilege, type safety, input validation

STRIDE Steps

1. Define the key assets and security requirements for the system
2. Design data flow diagram(s) for the system
3. Draw trust boundaries
4. Identify threats
5. Mitigate threats with controls
6. Validate that threats were mitigated

STRIDE Example

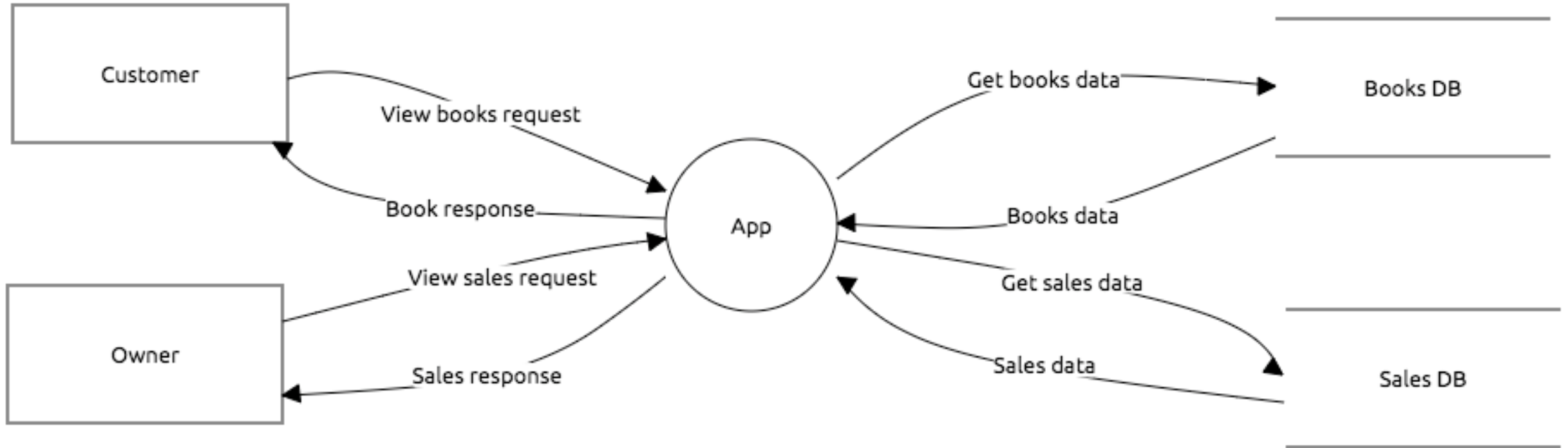
System Description

- A simple e-commerce book webshop:
 - Two types of users [**actors/external interactors**]: *customers* and the *shop owner* (system administrator)
 - One web application run by a server [**process**]
 - One database with customer data and transaction information (Sales DB) [**data store**]
 - One database with warehouse data about books in stock (Books DB) [**data store**]
- Interactions in this system (modelled as [**data flows**]):
 - Customers can send their shopping requests to the application, and will get web pages with information about available books
 - Owner will send information requests to the application, and will get web pages with sales data
 - Application can send requests to the Sales DB for the sales data
 - Application sends requests to the Books DB for the warehouse data

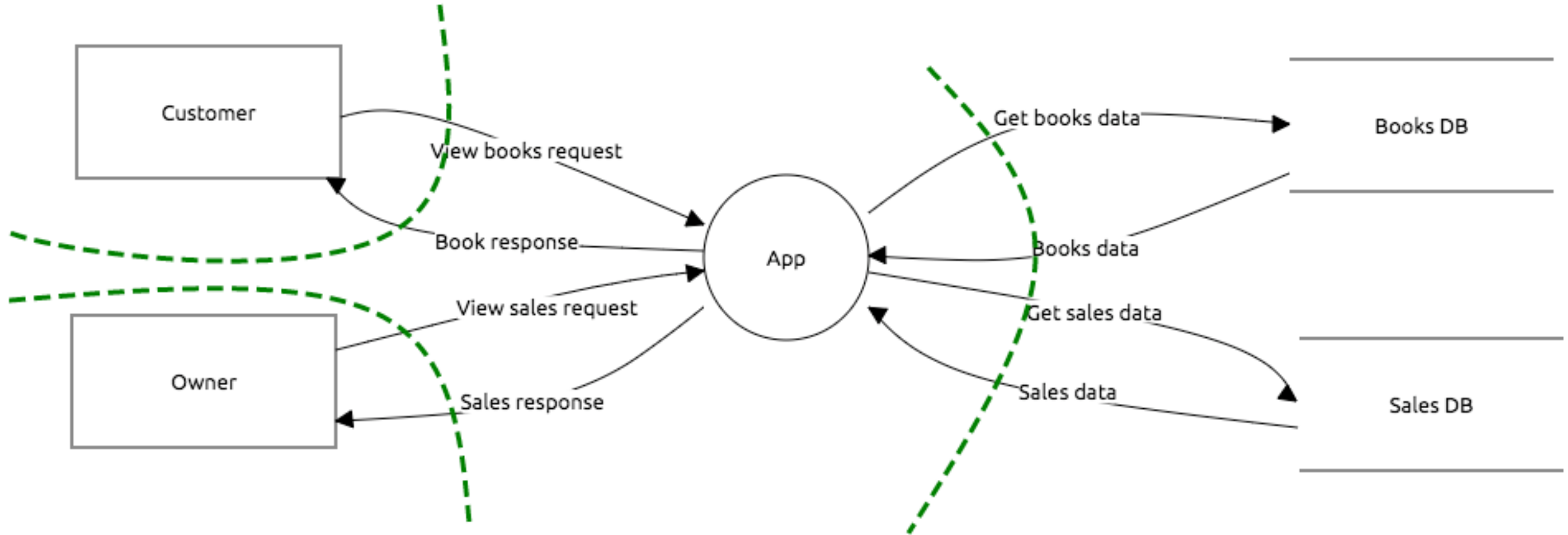
Assets and Requirements

- Assets: databases, web application process.
- Requirements:
 - Confidentiality, integrity and availability of sales data.
 - Integrity and availability of books data.
 - Integrity and availability of web app.

Data Flow Diagram (DFD)



DFD with trust boundaries



Trust boundaries demarcate trust zones

Generally, relevant threats cross the trust boundaries

STRIDE per element

Element	S	T	R	I	D	E
Actor	x		x			
Process	x	x	x	x	x	x
Data flow		x		x	x	
Data store		x		x	x	

Each element is the victim, not the perpetrator

STRIDE per interaction

#	Element	Interaction	S	T	R	I	D	E
1	Process	Process has outbound data flow to data store	x			x		
2		Process sends output to another process	x		x	x	x	x
3		Process sends output to an actor (code)	x		x	x	x	
4		Process sends output to an actor (human)			x			
5		Process has inbound data flow from data store	x	x			x	x
6		Process has inbound data flow from a process	x		x		x	x
7		Process has inbound data flow from an actor	x				x	x
8	Data flow	Crosses machine/trust boundary		x		x	x	
9	Data store	Process has outbound data to data store		x	x	x	x	
10		Process has inbound data from data store			x	x	x	
11	Actor	Actor passes input to a process	x		x	x		
12		Actor gets input from a process	x					

Some Threats

- Web app process:
 - Spoofing of Owner: somebody else gets Sales data.
 - Spoofing of Books and Sales data (incoming)
 - Customer denies sending requests (repudiation)
 - A database is offline (DoS); not answering requests
 - Customer connects with higher privilege, potentially getting more data than needed (EoP)*
 - * not really modelled in this diagram, but it can be extended to model privileges.

Take-aways

- **Risk management:** quantification and prioritization of threats. We decide on defensive strategies and implement controls based on our risks.
- **Threat modelling:** applied to brainstorm about possible attacks. The more we understand our threat landscape, the better we can prepare.
- **STRIDE** - a methodology to identify threats for software systems. Focuses on most typical scenarios.

References

- NIST SP 800-12 *An Introduction to Information Security*
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf> — a condensed introduction to security from the organisational perspective
- CyBOK *Risk Management and Governance*
<https://www.cybok.org/media/downloads/Risk-Management--Governance-issue-1.0.pdf>

Outlook

- In the first two lectures, we
 - gave an **Introduction to Security** and related **terminology**;
 - worked on **risk assessment and threat modeling**.
- This completes the main *managerial* component of our course, and allows us to move to the *technical* part.
- Next week we move to the topic of **Cryptography**, concretely starting with **Symmetric Encryption**
- Also related to Cryptography, towards the end of the course, we will discuss **Secure Computation Technologies**, enabled by cryptographic techniques

Stay Tuned.....

Questions?



Universiteit
Leiden

Bij ons leer je de wereld kennen